

VULNERABILITY INTELLIGENCE REPORT

MANAGING VULNERABILITIES · Lab 1

STUDENT	INSTRUCTOR	DATE	COURSE
HASSANI Mohammad Salem	Asen Grozdanov	January 07, 2026	Managing Vulnerabilities

PART 1 — VULNERABILITY DATABASES

Step 1.1 · NVD Navigation

The National Vulnerability Database (NVD) was explored to identify recent high-severity vulnerabilities. The search was filtered by CVSS score ≥ 9.0 to surface only Critical findings.

⚠ CVE-2025-64446 · Fortinet FortiWeb · CVSS 9.8 CRITICAL

CWE: CWE-23 — Relative Path Traversal

Attack Vector: Network (AV:N) · Low Complexity (AC:L) · No Privileges Required (PR:N)

Impact: Unauthenticated attackers may execute administrative commands via crafted HTTP requests, bypassing all security controls and fully compromising the WAF.

PoC Status: Public exploit code available on GitHub (WatchTowr Labs) — elevated script-kiddie risk.

Mitigation: Upgrade to FortiWeb 8.0.2 immediately.

Step 1.2 · CISA KEV Catalog Analysis

The CISA Known Exploited Vulnerabilities (KEV) catalog was sorted by Date Added to surface threats actively exploited in the wild. The following entries were added on 2026-02-03:

CVE ID	Vendor / Product	Vulnerability Name	Date Added
CVE-2019-19006	Sangoma FreePBX	Improper Authentication	2026-02-03
CVE-2025-64328	Sangoma FreePBX	OS Command Injection	2026-02-03
CVE-2021-39935	GitLab CE/EE	Server-Side Request Forgery	2026-02-03

PART 2 — OSINT & ANALYSIS

Step 2.1 · OSINT Aggregation

Feedly was configured as the primary aggregation platform, ingesting feeds from BleepingComputer and The Hacker News. The following key trend was identified on 2026-02-04:

- **Key Trend:** Ransomware groups are increasingly weaponising legacy vulnerabilities alongside novel zero-days. A confirmed instance is the active exploitation of VMware ESXi flaw **CVE-2025-22225** by ransomware gangs — despite vendor patches having been available since 2025.

Step 2.2 · Deep Dive Technical Analysis — CVE-2025-64446

This CVE was selected for deep analysis due to its critical severity (CVSS 9.8) and the widespread enterprise deployment of Fortinet FortiWeb as a perimeter Web Application Firewall.

Vulnerability Class	Relative Path Traversal (CWE-23)
Attack Vector	Network — remotely exploitable without a VPN or local access
Complexity	Low (AC:L) — no race conditions or special configurations required
Authentication	None (PR:N) — no credentials needed; unauthenticated exploitation possible
User Interaction	None (UI:N) — fully automated attack chain
Confidentiality	High — intercept TLS-decrypted traffic passing through the WAF
Integrity / Avail.	High / High — full WAF compromise; service disruption possible
PoC Availability	Public (GitHub · WatchTowr Labs) — weaponised tooling accessible
Official Mitigation	Upgrade to FortiWeb 8.0.2 — no workaround available

Step 2.3 · Correlation & Prioritization Matrix

Vulnerabilities were cross-referenced against CISA KEV and active threat intelligence feeds to distinguish theoretical risk from confirmed exploitation.

Vulnerability	CVSS	Active Exploit?	Business Impact	Priority
CVE-2025-64446 (Fortinet FortiWeb)	9.8 Critical	YES — Public PoC (WatchTowr Labs)	High Edge / Perimeter Device	🔴 P1 — Immediate (Patch within 24 h)
CVE-2025-22225 (VMware ESXi)	High	YES — Active Ransomware campaigns	Critical Core Server Infrastructure	🟡 P2 — Urgent (Audit + Patch ASAP)
CVE-2026-20805 (Microsoft Windows)	5.5 Medium	YES — CISA KEV confirmed	Medium End-User Workstations	🟢 P3 — Scheduled (Next patch cycle)

PART 3 — SYNTHESIS & REPORTING

Step 3.1 · Executive Summary

TO: Chief Information Security Officer (CISO)
FROM: Security Analyst — Threat Intelligence
DATE: February 4, 2026
SUBJECT: Critical Threat Alert — Fortinet FortiWeb & VMware ESXi

OVERVIEW

This month's threat intelligence cycle has surfaced two critical risks requiring immediate executive attention: the active exploitation of perimeter firewalls via a public proof-of-concept, and renewed ransomware campaigns targeting

core virtualisation infrastructure.

CRITICAL FINDINGS

- **Fortinet FortiWeb (CVE-2025-64446):** A critical authentication-bypass flaw (CVSS 9.8) with a public exploit is actively being scanned in the wild. Any internet-facing FortiWeb appliance is at immediate risk.
- **VMware ESXi (CVE-2025-22225):** CISA confirmed on 2026-02-04 that ransomware groups are actively exploiting this flaw against unpatched ESXi hosts. Encryption of production workloads is a credible near-term risk.

RECOMMENDATIONS

- ✓ Patch all external-facing Fortinet FortiWeb appliances to version 8.0.2 within 24 hours.
- ✓ Conduct an immediate audit of all ESXi hosts to confirm application of March 2025 security updates.
- ✓ Validate network segmentation around virtualisation clusters to limit lateral movement exposure.

Step 3.2 · Technical Appendix

- **NVD (nvd.nist.gov):** Primary source for CVE verification, CVSS scoring, and CWE classification.
- **CISA KEV Catalog:** Authoritative list of vulnerabilities with confirmed in-the-wild exploitation; used to prioritise remediation over theoretical severity alone.
- **Feedly:** RSS/API aggregation platform for continuous monitoring of BleepingComputer, The Hacker News, and vendor advisories.

Methodology: High-severity NVD alerts were cross-referenced against the CISA KEV catalog to distinguish theoretical risk from confirmed active exploitation. Feedly provided real-time signal on in-the-wild activity.

Step 3.3 · Reflection

- **Key Insight:** The presence of CVE-2019-19006 (a 2019 FreePBX flaw) being added to the KEV catalog in 2026 confirms that threat actors continue to weaponise legacy vulnerabilities. Legacy system hygiene is therefore as operationally critical as rapid zero-day patching.
- **Professional Application:** This lab accurately simulates a core SOC analyst workflow: continuous feed monitoring → database verification → correlation → actionable executive intelligence.